

Tietoturva-auditoinnin palvelumalli pk-yritykselle

1. Johdanto

Tämä dokumentti kuvaa työharjoittelun aikana kehitetyn tietoturva-auditoinnin palvelumallin pk-yritykselle. Palvelumallin tavoitteena on tarjota vaiheistettu ja toistettava menetelmä organisaation tietoturvan arviointiin sekä kehittämiskohteiden tunnistamiseen.

Palvelumallin suunnittelussa hyödynnettiin Traficomın Kyberturvallisuuskeskuksen ohjeistuksia, ISO/IEC 27001- ja 27002-standardeja sekä NIST Cybersecurity Framework -viitekehystä. Mallin toimivuutta testattiin harjoittelun aikana rakennetussa POC-ympäristössä avoimen lähdekoodin auditointityökaluilla.

Palvelumalli on suunniteltu erityisesti pk-yritysten tarpeisiin, joissa tietoturvan kehittämiseen käytettävissä olevat resurssit ovat usein rajallisia.

2. Palvelumallin tavoite

Palvelumallin tavoitteena on:

- arvioida organisaation tietoturvan nykytila
- tunnistaa hallinnollisia ja teknisiä puutteita
- tukea riskienhallintaa
- tuottaa kehitysehdotuksia tietoturvan parantamiseksi
- mahdollistaa auditointien toistaminen yhtenäisellä tavalla

Mallia voidaan käyttää sekä sisäisissä että ulkoisissa tietoturva-auditoinneissa.

3. Palvelumallin rakenne

Vaihe	Sisältö	Tuotos
1	Auditoinnin suunnittelu	Auditointisuunnitelma
2	Hallinnollinen auditointi	Hallinnollinen checklist
3	Tekninen auditointi	Tekninen checklist ja tekniset testit
4	Tulosten analysointi	Havaintojen arviointi

Vaihe	Sisältö	Tuotos
5	Kehityssuositukset	Toimenpidesuositukset
6	Raportointi	Auditointiraportti

4. Auditoinnin vaiheet

Vaihe 1: Auditoinnin suunnittelu

Auditointi aloitetaan määrittelemällä tavoitteet, rajaukset sekä käytettävät viitekehykset.

Suunnitteluvaiheessa määritellään:

- auditoinnin kohde
- auditoinnin laajuus
- käytettävät menetelmät
- käytettävät työkalut
- raportointitapa

Suunnittelun tuloksena syntyy auditointisuunnitelma.

Vaihe 2: Hallinnollinen auditointi

Hallinnollisessa auditoinnissa arvioidaan organisaation tietoturvan hallintaa ja toimintatapoja.

Tarkasteltavia osa-alueita ovat:

- tietoturvapolitiikka
- riskienhallinta
- henkilöstön koulutus
- käyttöoikeuksien hallinta
- varmuuskopiointi
- jatkuvuussuunnittelu
- tietoturvapoikkeamien käsittely

Arviointi toteutetaan hallinnollisen checklistin avulla.

Vaihe 3: Tekninen auditointi

Teknisessä auditoinnissa arvioidaan järjestelmien ja palveluiden suojaustasoa.

Tarkasteltavia osa-alueita ovat:

- salasanaikäytännöt

- ohjelmistopäivitykset
- verkkoturva
- käyttöoikeudet
- lokitus ja valvonta
- haavoittuvuuksien hallinta

Harjoittelussa tekninen auditointi toteutettiin Ubuntu Server -pohjaisessa POC-ympäristössä.

Käytetyt työkalut:

- Nmap
- OpenVAS / GVM
- Lynis
- Ubuntu-järjestelmän lokityökalut

Vaihe 4: Tulosten analysointi

Hallinnollisen ja teknisen auditoinnin tulokset yhdistetään kokonaiskuvaksi.

Analyysin tavoitteena on:

- tunnistaa vahvuudet
- tunnistaa puutteet
- arvioida riskit
- tunnistaa kehittämiskohteet

Tuloksia verrataan valittuihin viitekehyksiin ja auditoinnin tavoitteisiin.

Vaihe 5: Kehityssuositusten laatiminen

Auditoinnin perusteella laaditaan kehitysehdotuksia organisaation tietoturvan parantamiseksi.

Suositukset voivat liittyä esimerkiksi:

- käyttöoikeuksien hallintaan
- ohjelmistopäivityksiin
- palveluiden koventamiseen
- lokien seurantaan
- haavoittuvuuksien hallintaan
- henkilöstön tietoturvakoulutukseen

Suositukset priorisoidaan niiden vaikutuksen ja toteutettavuuden perusteella.

Vaihe 6: Raportointi

Auditoinnin tulokset dokumentoidaan raportiksi.

Raportti sisältää:

- auditoinnin tavoitteet
- käytetyt menetelmät
- auditoinnin havainnot
- analyysin
- kehityssuositukset
- johtopäätökset

Raportti toimii lähtökohtana organisaation tietoturvan jatkokehittämiselle.

5. Palvelumallin hyödyt pk-yritykselle

Palvelumalli tarjoaa pk-yrityksille selkeän ja kustannustehokkaan menetelmän tietoturvan arviointiin.

Mallin keskeiset hyödyt ovat:

- vaiheittainen toteutus
- selkeä dokumentointi
- avoimen lähdekoodin työkalujen hyödyntäminen
- tietoturvariskien tunnistaminen
- kehitystoimenpiteiden priorisointi
- auditointien toistettavuus